CYBERSECURITY

Nmap Network Scan • GoPhish Phishing Awareness • DNS Zone Transfer (AXFR)

Includes introductions, risk analysis, attack scenarios, mitigation strategies, organizational controls, and conclusions.

Shaik Thaheer
192425347
ITA1434

CO2-AT1

Report Analysis

1. Security Risk Analysis of Nmap Scan (20 Marks)

1.1 Introduction

Nmap (Network Mapper) is a widely used network discovery and security auditing tool. It helps security analysts identify hosts that are reachable on a network, determine which TCP or UDP ports are open, identify the services listening on those ports, and sometimes estimate the operating system and service versions. These results help administrators understand the system's exposed attack surface and decide which controls are needed.

In this scenario, the analyst scanned the authorized target 192.168.1.10 and found HTTP on port 80, SSH on port 22, and MySQL on port 3306. The report also contains operating-system and service-version information. An open port is not automatically a vulnerability: it means a service is listening and may be reachable. The actual risk depends on the software version, configuration, authentication, network exposure, and sensitivity of the data handled by the service.

1.2 Summary of Findings

Port / Service	Purpose	Main Risk
80 / HTTP	Delivers web pages and web applications.	Traffic may be unencrypted; vulnerable applications may permit injection, session theft, or unauthorized access.
22 / SSH	Provides encrypted remote administration.	Weak credentials, exposed administrative access, or outdated software may permit unauthorized login.
3306 / MySQL	Provides database connectivity.	An exposed database may be attacked using weak passwords, excessive privileges, or software vulnerabilities.
OS / service versions	Identify platform and software releases.	Version information can help attackers search for known vulnerabilities and choose targeted techniques.

1.3 Risks Associated with HTTP (Port 80)

HTTP is used to transfer web pages and application data between a browser and a web server. Standard HTTP does not encrypt the connection. If users submit passwords, session cookies, or other sensitive data over HTTP, an attacker who can observe or manipulate the network traffic may be able to read or alter that information. This risk is especially significant on untrusted networks.

A second risk comes from the web application itself. If input is not validated and database queries are constructed unsafely, attackers may attempt SQL injection. Other possible weaknesses include cross-site scripting (XSS), insecure file uploads, directory traversal, broken access controls, and vulnerable third-party components. These issues are not proven by the open port alone; they require further authorized testing.

An attacker may also attempt to discover hidden application paths, identify outdated frameworks, or exploit insecure session management. If the web server is misconfigured, it may reveal directory listings, error messages, backup files, or configuration details. Such information can help an attacker plan later attacks.

1.4 Risks Associated with SSH (Port 22)

SSH (Secure Shell) provides encrypted remote access for system administration, file transfer, and command execution. It is an important service, but exposing it to the internet or untrusted network segments can make it a target for repeated login attempts. If password authentication is enabled and users choose weak or reused passwords, an attacker may attempt password guessing or credential stuffing.

If an attacker obtains valid credentials, the level of damage depends on the account's permissions. A privileged account could allow changes to system configuration, installation of malicious software, access to sensitive files, or movement to other systems. Old SSH versions or insecure configuration may also contain known weaknesses. Exposing SSH does not mean that these weaknesses exist; administrators must verify the version and configuration.

SSH risk can increase when root login is permitted directly, multiple users share accounts, private keys are poorly protected, or former employees retain access. Unnecessary SSH access from all IP addresses also increases the number of systems that can attempt to connect.

1.5 Risks Associated with MySQL (Port 3306)

MySQL is a relational database management system that stores application records, customer information, transactions, and other data. Port 3306 is commonly used for MySQL connections. If the database accepts connections from untrusted networks, attackers may try weak or default credentials, exploit an outdated database version, or abuse excessive permissions.

Unauthorized database access can result in confidentiality, integrity, and availability failures. Confidentiality loss includes stealing personal or business information. Integrity loss includes modifying or deleting records. Availability loss includes disrupting applications by deleting data or exhausting database resources. If the

database account used by an application has unnecessary administrative privileges, a compromise of the application may also lead to broader database damage.

Database services should normally be reachable only by the application servers, administrators, or other explicitly authorized systems that need them. A database does not generally need to be publicly accessible simply because a web application uses it.

1.6 Risks from Operating-System and Service-Version Disclosure

Operating-system fingerprints and service banners can reveal product names, release numbers, and sometimes build details. Attackers may compare these details with public vulnerability databases to identify software that is no longer supported or has known security flaws. They may then prioritize systems that appear easier to compromise.

Version information is useful for defenders as well. It helps administrators identify unsupported software and plan updates. However, banners can be inaccurate or intentionally obscured, so a version match should be verified before concluding that a system is vulnerable. A reliable assessment combines version information with vendor advisories, configuration review, and authorized vulnerability testing.

1.7 How an Attacker Might Combine the Findings

An attacker could first use the scan results to map the available services, then research the detected versions and look for known weaknesses. If the HTTP application is vulnerable, the attacker may attempt to gain access through the web layer. If database access is unnecessarily exposed, the attacker may separately attempt authentication against MySQL. If SSH is reachable and credentials are weak or compromised, remote access may be possible. These are potential attack paths, not proof that the target is compromised.

The greatest risk can occur when services are connected. For example, a vulnerable web application may expose database credentials, while an overprivileged database account may permit more access than required. If administrative credentials are reused across services, one compromised account can affect several systems. Security assessment should therefore consider the complete system architecture rather than evaluating each port in isolation.

1.8 Recommended Security Measures

A. Secure HTTP and the Web Application

- Use HTTPS with valid TLS certificates for all web sessions and redirect HTTP requests to HTTPS.
- Keep the web server, framework, libraries, and plugins updated; remove unsupported components.
- Validate and safely handle user input. Use parameterized SQL queries rather than building queries by string concatenation.
- Apply secure session handling, appropriate cookie flags, access controls, and security headers.

- Disable directory listing, remove unnecessary sample pages, and avoid exposing backup or configuration files.
- Perform regular authorized web-application security testing and remediate verified findings.

B. Secure SSH

- Restrict SSH access to a VPN, management network, or approved administrator IP addresses.
- Prefer public-key authentication and protect private keys with appropriate permissions and passphrases.
- Disable direct root login and use individual accounts with least privilege.
- Disable password authentication where operationally appropriate and maintain a secure recovery process.
- Use rate limiting or intrusion-prevention controls to reduce repeated login attempts.
- Remove unused accounts and keys, patch SSH software, and review authentication logs.

C. Secure MySQL

- Block inbound port 3306 from public and untrusted networks using firewalls or security groups.
- Bind the database to a private interface where possible and allow only authorized application servers.
- Use unique, strong credentials and rotate them securely when exposure is suspected.
- Apply least privilege: application accounts should receive only the database permissions they require.
- Use encrypted connections where traffic crosses networks and protect backups with access controls and encryption.
- Patch MySQL, monitor database logs, test recovery procedures, and back up important data regularly.

D. General Network and Host Controls

- Apply a default-deny firewall policy and allow only business-required services.
- Use network segmentation to separate web servers, databases, and management systems.
- Maintain an asset inventory and a documented patch-management process.
- Deploy endpoint protection, centralized logging, alerting, and intrusion detection where appropriate.
- Repeat authorized scans after remediation to verify that unnecessary services are closed or filtered.

1.9 Conclusion

The Nmap report identifies three important exposed services: HTTP, SSH, and MySQL. HTTP may expose users to unencrypted traffic or application vulnerabilities; SSH may be targeted for unauthorized remote login; and MySQL may expose sensitive data if access is not restricted. Operating-system and version details can help attackers select targets. Open ports alone do not prove a vulnerability, but they show where security controls should be reviewed. Patching, strong authentication, network restrictions, least privilege, encryption, logging, and regular authorized assessments can substantially reduce the risk.

2. Phishing Awareness Analysis Using GoPhish (20 Marks)

2.1 Introduction

Phishing is a social-engineering attack in which an attacker impersonates a trusted person or organization to persuade a victim to click a link, reveal credentials, open a malicious attachment, or perform an unsafe action. Phishing often relies on urgency, fear, curiosity, authority, or a convincing imitation of a legitimate message.

GoPhish is a phishing simulation framework used by security teams to run authorized awareness exercises and measure employee responses. In the ABC Technologies Pvt. Ltd. campaign, 40% of employees clicked a phishing link, 20% entered login credentials, and several employees downloaded a malicious attachment. These results indicate that the organization needs to improve both employee awareness and technical protections.

2.2 Analysis of the Campaign Results

Observed Result	Interpretation	Possible Business Risk
40% clicked the link	A significant share of employees did not identify or verify the suspicious link.	Users may be redirected to credential-harvesting pages or harmful websites.
20% entered credentials	Some employees trusted a page or request that appeared legitimate.	Corporate accounts may be compromised if credentials are collected and reused.
Some downloaded attachments	Users may not have checked whether attachments were expected or safe.	Malware may execute, leading to data theft, ransomware, or device compromise.

The percentages should be interpreted in context. The report does not specify the total number of employees, whether the credential-entry percentage is measured against all recipients or only a subgroup, or whether any attachment actually executed malware. The campaign demonstrates risky behavior, but it does not by itself prove that real accounts were compromised.

2.3 Security Weaknesses Demonstrated by Employees

A. Failure to Verify Links and Senders

Clicking a link without checking the sender, destination domain, context, and purpose can expose employees to fake login pages or malicious websites. Display text may hide a different destination, and attackers can use lookalike domains that differ from the real domain by only a few characters. Employees should be trained to inspect links carefully and navigate to important services through known bookmarks or official websites.

B. Weak Credential Protection Habits

Entering login details into a page reached from an unexpected email suggests that employees may not verify the authenticity of the sign-in page. Stolen credentials can be used to access email, cloud services, internal applications, or other systems. Reuse of the same password across personal and corporate services increases the possible impact. Multi-factor authentication reduces risk, although phishing-resistant methods provide stronger protection than codes that can be relayed by an attacker.

C. Unsafe Handling of Attachments

Unexpected attachments may contain malicious macros, scripts, executable files, or documents that exploit software vulnerabilities. Downloading a file does not necessarily mean that it executed, but opening or enabling active content can create additional risk. Employees should verify unexpected files through a separate trusted communication channel and follow the organization's procedure for reporting suspicious messages.

D. Susceptibility to Social-Engineering Pressure

Phishing messages may claim that an account will be disabled, a payment is overdue, a package is waiting, or an urgent task must be completed immediately. Such pressure discourages careful checking. Employees should recognize urgency, secrecy, unusual payment requests, unexpected password-reset messages, and requests to bypass normal approval procedures as warning signs.

2.4 Potential Impacts on ABC Technologies

- Credential theft: Attackers may use collected usernames and passwords to access employee accounts and business systems.
- Malware infection: A malicious attachment may install spyware, ransomware, a remote-access tool, or another harmful program if it is executed successfully.
- Data breach: A compromised account may expose customer information, company documents, intellectual property, or confidential communications.
- Financial fraud: Attackers may impersonate managers or suppliers to request fraudulent transfers or changes to payment details.
- Business email compromise: A compromised mailbox can be used to send convincing phishing messages to coworkers, customers, and partners.
- Operational disruption: Malware or unauthorized access may interrupt business processes, require incident response, and damage customer trust.
- Compliance and reputational impact: Exposure of regulated or confidential information may lead to investigation, notification obligations, and reputational harm.

2.5 Recommended User-Awareness Programs

A. Regular, Practical Training

Provide onboarding training for new employees and short refresher sessions throughout the year. Training should use realistic examples of phishing emails, fake login pages, suspicious attachments, QR-code phishing, impersonation, and business email compromise. It should explain the warning signs and show employees exactly how to report a suspected attack.

B. Authorized Phishing Simulations

Run periodic GoPhish simulations with appropriate authorization and privacy safeguards. Use different scenarios and measure trends over time, such as link-click rates, credential-submission rates, attachment interactions, and reporting rates. The purpose should be to improve organizational resilience, not to shame individual employees. Results should be handled confidentially and used to target additional training where needed.

C. Teach a Simple Verification Routine

- Check whether the sender address and domain match the organization or person expected.
- Pause before clicking a link, especially when the message creates urgency or asks for sensitive information.
- Verify payment changes, password requests, and unusual instructions through a separate trusted channel.
- Do not enter passwords or MFA codes after following an unexpected email link.
- Do not enable macros or bypass security warnings for an unexpected attachment.
- Report suspicious messages using the organization's approved reporting button or help-desk process.

D. Build a Positive Reporting Culture

Employees should feel safe reporting a suspicious email even if they clicked a link by mistake. Fast reporting can allow security staff to remove similar messages, block malicious domains, reset credentials, and isolate affected devices. Clear instructions and timely feedback help employees learn from simulations and real incidents.

2.6 Recommended Email Security Controls

A. Secure Email Gateway and Filtering

Deploy email filtering to identify spam, impersonation, malicious URLs, suspicious attachments, and known phishing indicators. Configure policies to quarantine or reject high-risk messages. Filtering should be reviewed regularly because attackers change domains, wording, and attachment techniques to evade detection.

B. SPF, DKIM, and DMARC

SPF identifies mail servers authorized to send mail for a domain. DKIM adds a cryptographic signature that allows receivers to verify that signed parts of a message have not been altered and that the signature is associated with a domain. DMARC allows a domain owner to specify how receivers should handle messages that fail relevant authentication and alignment checks, and provides reporting. These controls help reduce

domain spoofing but do not stop every phishing attack, including messages sent from compromised legitimate accounts or lookalike domains.

C. URL and Attachment Protection

Use URL reputation checks, time-of-click protection, and sandbox analysis for suspicious links and attachments. Block dangerous file types where justified by business needs, inspect compressed files, and prevent risky active content from executing by default. Keep endpoint and office software updated so known vulnerabilities cannot be easily exploited.

D. Multi-Factor and Phishing-Resistant Authentication

Require MFA for email, remote access, administrative accounts, and important cloud applications. Prefer phishing-resistant authentication such as passkeys or hardware security keys where supported. MFA is an additional layer rather than a substitute for secure passwords, user training, conditional access, and monitoring.

E. Endpoint Detection and Response

Use centrally managed endpoint protection to detect suspicious processes, malicious scripts, unauthorized persistence, and unusual network connections. Keep devices patched and restrict local administrator privileges. Ensure security teams can isolate an endpoint quickly if a suspicious attachment is opened or malware is detected.

2.7 Organizational Policies and Incident Response

- Create a written acceptable-use and email-security policy that defines safe handling of links, attachments, credentials, and sensitive data.
- Establish a simple reporting process and a dedicated security contact or reporting button.
- Require verification through a separate channel for payment changes, requests for gift cards, bank-detail changes, and other high-risk transactions.
- Use least privilege so employee accounts have only the access needed for their roles.
- Prohibit sharing passwords and MFA codes; use an approved password manager where appropriate.
- Define a response procedure for suspected phishing: report the message, remove it from mailboxes where possible, assess link or attachment interaction, reset exposed credentials, revoke active sessions, and isolate affected devices if necessary.
- Preserve relevant logs and evidence, communicate with affected teams, and document lessons learned after an incident.
- Review simulation results, employee reporting rates, time to report, and repeat patterns to measure whether controls are improving.

2.8 Measuring Improvement

ABC Technologies should compare future campaign results with the baseline, while accounting for differences in scenario difficulty and employee groups. Useful measures include the proportion of employees who click, the proportion who submit credentials, the proportion who report the message, and the time between delivery and reporting. A falling click or credential-submission rate and a rising reporting rate indicate improvement. Metrics should be used to guide training and technical changes rather than as the sole measure of employee performance.

2.9 Conclusion

The GoPhish campaign shows that a substantial number of employees may be vulnerable to phishing, credential theft, and malicious attachments. Successful prevention requires more than training alone. ABC Technologies should combine regular awareness exercises, a supportive reporting culture, secure email filtering, SPF/DKIM/DMARC, attachment and URL analysis, phishing-resistant MFA, endpoint protection, and a documented incident response process. These measures can reduce both the likelihood and impact of social-engineering attacks.

3. DNS Zone Transfer (AXFR) Security Analysis (10 Marks)

3.1 Introduction

The Domain Name System (DNS) translates human-readable domain names into IP addresses and provides other records used by services such as email. A DNS zone contains records for a domain, including hostnames and service information. AXFR is a DNS protocol operation used to transfer a zone from a primary DNS server to an authorized secondary server so that both can maintain consistent records.

In the given assessment, the DNS server allows a successful zone transfer that exposes internal hostnames, mail servers, and other DNS records. If the transfer is available to unauthorized systems, it can disclose information that should not be public. The key issue is not that AXFR exists—legitimate DNS replication requires it—but that access is not properly restricted.

3.2 Security Implications of Exposed DNS Records

- Information disclosure: Hostnames, IP addresses, mail servers, and service records may reveal details about the organization's infrastructure.
- Network mapping: Names such as admin, database, development, VPN, or mail hosts may help an attacker understand system roles and relationships.
- Target identification: Attackers can prioritize systems that appear important or outdated for further authorized-looking reconnaissance or unauthorized probing.
- Phishing preparation: Mail and domain details can help attackers create more convincing messages or impersonation attempts.
- Exposure of non-public systems: Internal records may reveal staging, test, or administrative systems that were not intended to be publicly discoverable.
- Risk amplification: DNS data can be combined with other public information, leaked credentials, or service vulnerabilities to make later attacks more targeted.

A successful zone transfer does not by itself grant login access or prove that any server is vulnerable. It primarily provides reconnaissance information that can make subsequent attacks more efficient.

3.3 How Attackers Could Use the Information

1. Collect the transferred records and group hostnames by likely function, such as web, mail, database, or administration.
2. Use the names and addresses to identify which systems warrant further security review.
3. Compare publicly identifiable services and software information with known vulnerabilities.
4. Use exposed mail configuration and naming conventions to craft targeted phishing or impersonation attempts.

5. Combine DNS information with other findings to build a clearer picture of the organization's attack surface.

3.4 Recommended DNS Security Measures

A. Restrict Zone Transfers

Configure the authoritative DNS server to permit AXFR only to explicitly authorized secondary DNS servers. Use access control lists to limit transfers to the approved IP addresses of those servers. Do not allow zone transfers from arbitrary internet hosts.

B. Authenticate Transfers with TSIG

Use Transaction Signature (TSIG) keys to authenticate DNS messages between servers that support it. TSIG helps verify that a transfer request comes from a trusted peer and that the message has not been tampered with. Keys must be generated, stored, rotated, and protected securely.

C. Separate Internal and External DNS

Maintain separate internal and external DNS views or zones where appropriate. Publish only the records required for public services and avoid placing internal hostnames or private infrastructure details in public zones. Review records for old test systems, retired hosts, and unnecessary disclosures.

D. Monitor, Patch, and Test

- Enable DNS logging and alert on unexpected AXFR attempts or unusual query patterns.
- Keep DNS server software patched and disable unused features and services.
- Review zone-transfer permissions whenever secondary servers or network addresses change.
- Perform periodic authorized configuration checks to confirm that unauthorized transfer requests are refused.
- Document DNS ownership, backup and recovery procedures, and the approved list of secondary servers.

3.5 Conclusion

An unrestricted DNS zone transfer can reveal valuable information about an organization's infrastructure and help attackers conduct more targeted reconnaissance. The organization should restrict AXFR to authorized secondary servers, use ACLs and TSIG authentication, separate internal and external DNS data, patch DNS software, and monitor logs. These steps preserve legitimate DNS replication while reducing unnecessary information disclosure.